

AI-Powered Adaptive UEBA for Insider Threat Detection

Comprehensive Project Understanding, Presentation Guide & Viva Question Bank

Academic Context: M.Tech in CSE	Student: Mr. Chetan Shrikant Lokhande (25PCS009)
Institution: D.K.T.E. Society's TEI, Ichalkaranji	Guide: Prof. S. R. Patil
Affiliation: Shivaji University, Kolhapur	Dataset: CMU CERT Insider Threat Dataset r5.2
Registration: July 2026	Expected Completion: June 2027

SECTION 1 — PROJECT IN ONE PAGE

- 1. Problem Statement:** Adaptive User and Entity Behavior Analytics (UEBA) systems dynamically adjust profiles to reflect changing user roles. However, this introduces a critical vulnerability: *slow-escalation baseline poisoning*. A patient insider escalating anomalous activity by ~5% per month causes an ungoverned model to quietly absorb the attack as normal, causing detection rates to drop from 94% down to 22%.
- 2. Proposed Solution:** A 4-layer architecture combining 44 continuous behavioral features on CMU CERT r5.2, a 4-stage baseline update governance engine with peer-group anchors, hybrid risk fusion (XGBoost + SMOTE, SVM, Isolation Forest), exact TreeSHAP attributions, and an evidence-grounded Claude 3.5 Sonnet LLM chatbot.
- 3. Research Contribution:** The 4-stage baseline governance engine. It mathematically separates legitimate role transfers from unilateral attack drift, sustaining a ~93% detection rate under 6-month poisoning attacks where ungoverned baselines fail.
- 4. Key Experimental Results:**

Metric / Benchmark	Empirical Result	Operational Significance
Model Fusion (E1)	AUC 0.9782, F1 0.9412	Outperforms SVM (0.8842) & XGBoost (0.9415)
Full Test Scale (130k)	Recall 99.78%, Precision 100%	3,705 / 3,713 threats caught with 0 False Alarms
Ungoverned Poisoning (E2)	Detection drops 94% -> 22%	Proves ungoverned baseline collapse
Governed Defense (E3)	Sustains ~93.0% Detection	Suppresses 19 poisoned baseline updates
Drift Disambiguation (E4)	94.00% Acc, 4.00% FSR	Distinguishes role changes from attacks
LLM Faithfulness (E5)	Score 0.9555 (FaithLens)	Factuality 97.17%, zero hallucinated claims

Explain Project in 30 Seconds:

'My M.Tech project addresses slow-escalation baseline poisoning in User and Entity Behavior Analytics (UEBA). While dynamic baselines accommodate work changes, an insider can slowly escalate activity by 5% per month to train ungoverned models to ignore them. I developed a novel 4-stage baseline governance engine with peer-group anchors that prevents poisoning, maintaining a 93% detection rate on the CMU CERT dataset where ungoverned models collapse to 22%. Combined with a hybrid XGBoost-SVM-Isolation Forest risk fusion model and SHAP-grounded Claude LLM explanations scoring 0.9555 on FaithLens, the system delivers an end-to-end SOC command center.'

SECTION 2 — COMPLETE PROJECT UNDERSTANDING

- **UEBA:** Analyzes multi-channel telemetry (logon, USB, email, file, HTTP) to establish normal behavioral profiles and flag threat deviations.
- **Insider Threat:** Malicious activity originating from authenticated entities with legitimate access privileges.
- **Why Perimeter Fails:** Firewalls and IDS defend external borders; insiders use authorized credentials inside trust boundaries.
- **Adaptive Baselines:** Automatically update user profiles over time to accommodate benign workflow shifts.
- **Slow-Escalation Poisoning:** Adversaries deliberately increment exfiltration by small deltas (e.g., +5%/month) so ungoverned sliding windows absorb the malicious trajectory as normal.

SECTION 3 — RESEARCH GAP AND NOVELTY

Research Gap: Prior literature on CMU CERT r5.2 (BRITD, MambaITD, Evidential Clustering) focuses purely on instantaneous classification metrics and statistical thresholding without defending against slow-rate baseline manipulation.

Novelty & Contribution: The 4-stage governance engine with role-matched peer anchors. It evaluates drift acceleration, peer divergence, and 7-day monotonic trends to gate updates, sustaining 93% detection fidelity.

SECTION 4 — SYSTEM ARCHITECTURE & DATASET

The system follows a 4-layer architecture: Data Layer (CERT r5.2 ingestion & 44 features), Intelligence Layer (Hybrid ML fusion & 4-stage governance), Backend Layer (Django REST, Celery async queues, Redis broker, PostgreSQL), and Presentation Layer (React 18 analyst dashboard).

Dataset: CMU CERT Insider Threat Dataset r5.2 containing 692,645 continuous daily feature vectors across 6 CSV log modalities (logon, device, email, file, http, psychometric), partitioned into an 80% train split (562,594 rows) and a 20% held-out test split (130,051 rows).

SECTION 8 & 9 — ML MODELS & 4-STAGE GOVERNANCE

Risk Fusion Equation:

$$\text{RiskScore} = (0.35 * P_{\text{xgb}} + 0.25 * S_{\text{IF}} + 0.20 * D_{\text{peer}} + 0.15 * D_{\text{user}} + 0.05 * D_{\text{drift}}) * 100$$

4-Stage Governance Gates:

1. *Stage 1 (Drift Acceleration S_1):* Evaluates mean differential r_{bar} . Pass if $S_1 < 0.50$.
2. *Stage 2 (Peer Divergence S_2):* Evaluates $\Delta_{\text{peer}} = \max(0, D_{\text{user}} - D_{\text{peer}})$. Pass if $S_2 < 0.45$.
3. *Stage 3 (Monotonic Trend S_3):* Evaluates 7-day directional step ratio μ . Pass if $S_3 < 0.75$.
4. *Stage 4 (Composite Gating S_{drift}):* $S_{\text{drift}} = 0.35*S_1 + 0.40*S_2 + 0.25*S_3$. If $S_{\text{drift}} \geq 0.60$, update is SUPPRESSED and baseline is frozen.

SECTION 16 — EXPERIMENTAL RESULTS

In Experiment E2, an ungoverned baseline's detection rate collapsed from **94.0% to 22.0%** by Month 6 under 5%/month poisoning. In Experiment E3, our governed baseline sustained a **~93.0% detection rate** across all 6 months. In Experiment E4, drift classification achieved **94.00% accuracy** with only a **4.00% False Suppression Rate**. In Experiment E5, LLM explanations achieved an overall FaithLens score of **0.9555**.

SECTION 20 & 23 — VIVA QUESTIONS & RAPID REVISION

Top Viva Question 1: How do you prevent data leakage?

Answer: We enforce a strict chronological train/test split (80% train / 20% test). We never use random k-fold cross validation, which would cause future telemetry to leak into past training vectors.

Top Viva Question 2: How does the governance engine distinguish job promotions from attacks?

Answer: Stage 2 checks peer divergence. In a promotion, the user's vector shifts toward their new role's peer centroid, keeping peer divergence low. In an attack, the user drifts unilaterally away from peers, triggering suppression.

Top Viva Question 3: How do you prevent LLM hallucinations?

Answer: We build immutable JSON Evidence Objects containing TreeSHAP attributions and 7-day risk trajectories, passing them to Claude under strict prompt constraints. Tested on the FaithLens rubric, our summaries achieved 97.17% factuality and a 0.9555 overall score.